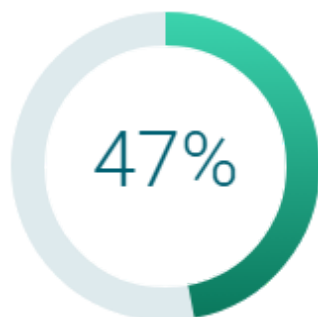


2026 ANNUAL CYBER-THREAT REPORT

Initial Access Trends

Traditionally, attackers first gained access with low privileges, then worked to escalate, a delay that bought defenders time. In 2025, however, adversaries often secured high-level control from the very start. In 47% of customer incidents, attackers entered with elevated privileges, shrinking the critical window defenders once had to detect escalation and enabling near-immediate movement to their primary objectives.



Percentage of incidents where attackers entered with elevated privileges

In this section of the report, we break down the entry techniques we saw in real-world customer incidents. We start with the deception-led attacks that defined the year, then shift to exposure-led access, dissecting the 2025 vulnerability landscape.

These trends illustrate that defending the front door requires a two-pronged strategy:



another that delivers comprehensive asset visibility with rapid mitigation for technical exposures across the hybrid enterprise.

Social Engineering Redefines How Attackers Gain Initial Access



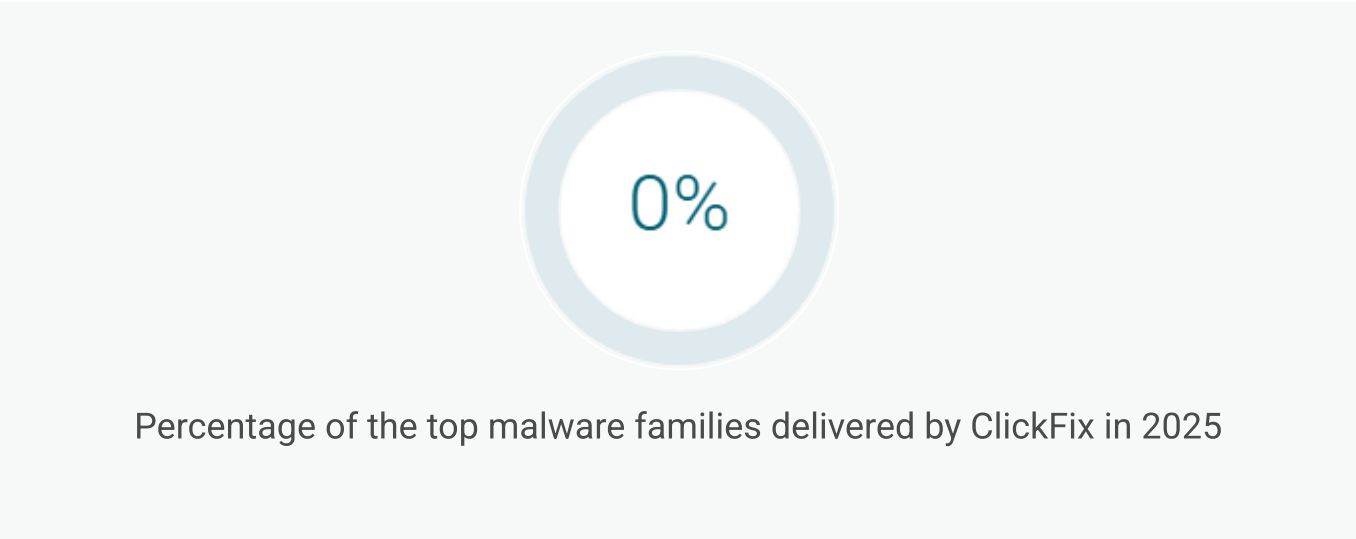
The top initial access techniques in customer incidents have remained consistent since 2023. While supply-chain compromise and replication through removable media rounded out the top 5, the leading trio again jostled for the top spot. These tactics stay popular because they exploit human trust, curiosity, and moments of inattention at a scale defenders can’t reliably stop in real time.

What changed in 2025 wasn’t the “what,” but the “how.” Attackers executed these staples differently, with social engineering acting as the common accelerator across nearly every major initial access path.

The most impactful initial access methods covered in the following sections all lean on this theme: The fastest path to initial access is through people, not novelty. AI likely supported this shift by eliminating language barriers and lowering the effort required to craft convincing narratives.

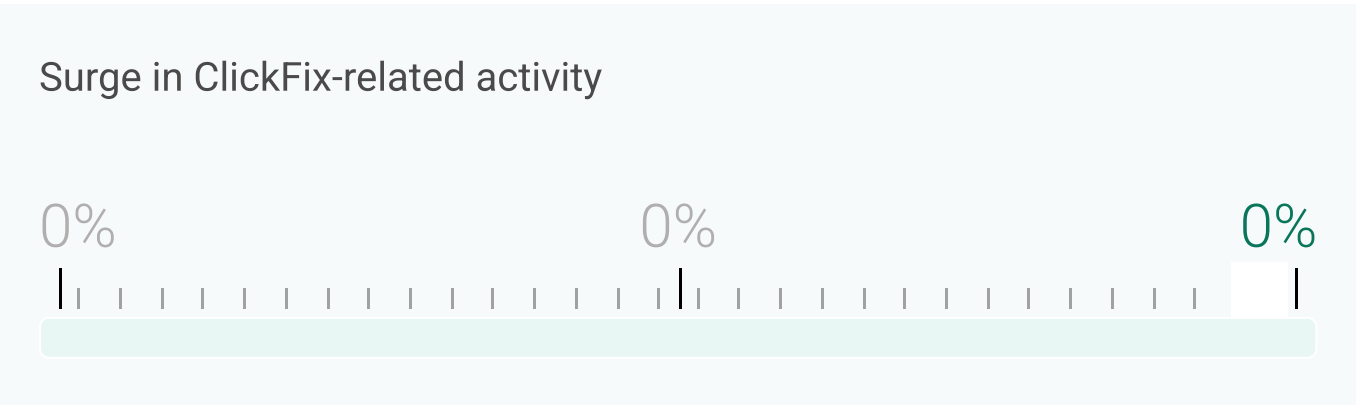
ClickFix: From Copy-Paste to Compromise

“ClickFix” facilitated the delivery of 59% of the top malware families in 2025, showing that initial access lures have moved beyond “click the link” or “open the attachment.” ClickFix blends phishing-style social engineering (coaching users into taking a harmful action) with drive-by compromise (where the “trigger” can be as simple as visiting a webpage). And because the activity runs through legitimate system functions, it can slip past email gateways, sandboxes, and some endpoint detection systems—shifting the fight from perimeter prevention to defense in depth and catching follow-on endpoint and identity behavior that ClickFix sets in motion.



Quiet Debut to Industrialized Abuse

First observed in October 2023, ClickFix is a social engineering technique that turns “troubleshooting” into an attack. Victims are tricked into running malicious commands themselves, often [under the guise of completing a CAPTCHA](#), clearing a browser security warning, or installing a critical system update (see Figure 1).



By early 2025, underground recruitment posts were advertising for ClickFix developers and “specialists.” After that, we observed a [200% surge in ClickFix-related activity](#) as adversaries began industrializing the technique to scale it—operating more like legitimate businesses by hiring talent to expand capacity and increase returns. By late 2025, the prominent ransomware group “Interlock” had adopted ClickFix as a primary initial access method, a strong indication that the technique isn’t just a nuisance, but effective even for mature ransomware-as-a-service (RaaS) operations.

ClickFix is even outgrowing its Windows roots. We investigated incidents where macOS users were targeted via ClickFix, leading to the delivery of the “Atomic” macOS infostealer. By the end of 2025, the same playbook was being used to deploy payloads ranging from ransomware to cryptocurrency miners, showing how a single delivery method can support very different objectives.

birdrepnet.com
Verify you are human by completing the action below.

Verification Steps

To better prove you are not a robot, please:

1. Press & hold the Windows Key **⊞** + **R**.
2. In the verification window, press **Ctrl + V**.
3. Press **Enter** on your keyboard to finish.

You will observe and agree:

☒ "I am not a robot - reCAPTCHA Verification ID: 738822"

Perform the steps above to finish verification. **Verify**

birdrepnet.com Needs to review the security of your connection before proceeding.

Verifying you are human
This may take a few seconds **CLOUDFLARE**

Step 1/2 On your MacOS
Press **⌘ Command** + **Space**, type "Terminal", and press **Return**.

Step 2/2 Run the Verification
Press **⌘ Command** + **V** in terminal and press **Return** to verify.

⌚ We're preparing your access... Verification Copied!

terminal **Return**

Time Remaining: 0:51
1655 users in your region have verified successfully in the last hour. **VERIFY**

Your IP: 173.170.21.50 Ray ID: 5675965621b405c7

☐ Verify you are human **CLOUDFLARE**
Errors • Terms

circleebuildings.net needs to review the security of your connection before proceeding.

Unusual Web Traffic Detected
Our security system has identified irregular web activity originating from your IP address. Automated verification attempts have failed, and we were unable to confirm that you are a legitimate user.

To proceed with verification, please follow these steps:

1. Press **⊞ Win** + **R** to open Run.
2. Copy and paste **Ctrl + V** the following command:

Verification Code **Copy**
Cloudflare protection - verify with code: 61Z-PAB

3. Press **Enter** and wait for confirmation.

This manual verification step helps us ensure that your connection is secure and not part of an automated request. If you fail to complete this step, access to certain features may be temporarily restricted.

Ray ID: e09418dc2bc3e726
Performance & security by Cloudflare

To verify your request follow the instructions below

- Press the Windows Button **⊞** + **R**
- Press **CTRL + V**
- Press **Enter**

** Figure 1: Common ClickFix Variations*

Why Traditional Awareness Fails Against ClickFix

ClickFix is best countered by shifting attention from file- or link-based detections to risky user-initiated execution. Because the technique pushes targets to run commands through legitimate interfaces (like the Windows Run dialog) and often hides behind trusted brands like Cloudflare, Google Chrome, and Microsoft, defenses are strongest when they can detect and contain abnormal command execution and follow-on behavior holistically across endpoint and identity telemetry.

Traditional security awareness still matters, but the guidance must change. “Don’t click suspicious links” won’t catch ClickFix. Training should condition users to treat unexpected CAPTCHAs, browser warnings, and “urgent” update prompts as potential attack steps—especially in industries where web-based workflows and self-service troubleshooting are routine (such as the technology, finance, health care, and education sectors).

AI adds both opportunity and risk to this playbook. While we haven’t seen AI-generated ClickFix lures at scale yet, ClickFix is well-suited for AI augmentation, from generating personalized fake error messages based on a target’s browsing behavior to automatically creating localized versions in multiple languages.

To get in front of AI-based ClickFix attacks, organizations should pair user awareness with AI-assisted behavioral detection that can spot anomalous user actions consistent with ClickFix execution, enabling faster investigation and response as lure quality improves.



Take Action Against ClickFix

- Disable or restrict Windows Run (Win + R) via Group Policy Objects (GPOs), as ClickFix relies on users pasting attacker-provided commands into the Run dialog box.
- Restrict PowerShell scripting by enabling Constrained Language Mode. ClickFix uses PowerShell to deliver advanced payloads like ransomware or cryptocurrency miners, so constraining its functionality hinders attackers' ability to execute malicious scripts.
- Train employees to recognize fake CAPTCHA pages and deceptive prompts. Social engineering is central to ClickFix, so regular training is essential to reduce the risk of human error that these campaigns depend on.

Scattered Spider's Social Engineering Drives Valid Account Abuse

ClickFix cast a wide net in 2025, but the year's highest-impact intrusions took a sharper, more direct path: the IT help desk, i.e., the custodians of access. Adversaries manipulated support staff into handing over valid credentials, then blended into normal traffic and sidestepped the alarms that noisy exploits typically trigger. By reducing technical reliance in favor of simpler, bolder, and faster tactics, attackers like "Scattered Spider" proved that the deadliest route to initial access is a legitimate identity—willingly handed over by someone who's been deceived.

In September 2025, UK authorities arrested alleged "Scattered Spider" member "EarthtoStar" in connection with over 120 network intrusions targeting US organizations.

ReliaQuest shared research on Scattered Spider's evolving tactics with law enforcement as part of an ongoing information-sharing partnership.

The arrest, along with other arrests of individuals tied to Scattered Spider in 2025, likely disrupted the group's operations and forced remaining members to tighten operational security, temporarily reducing its high-profile targeting.

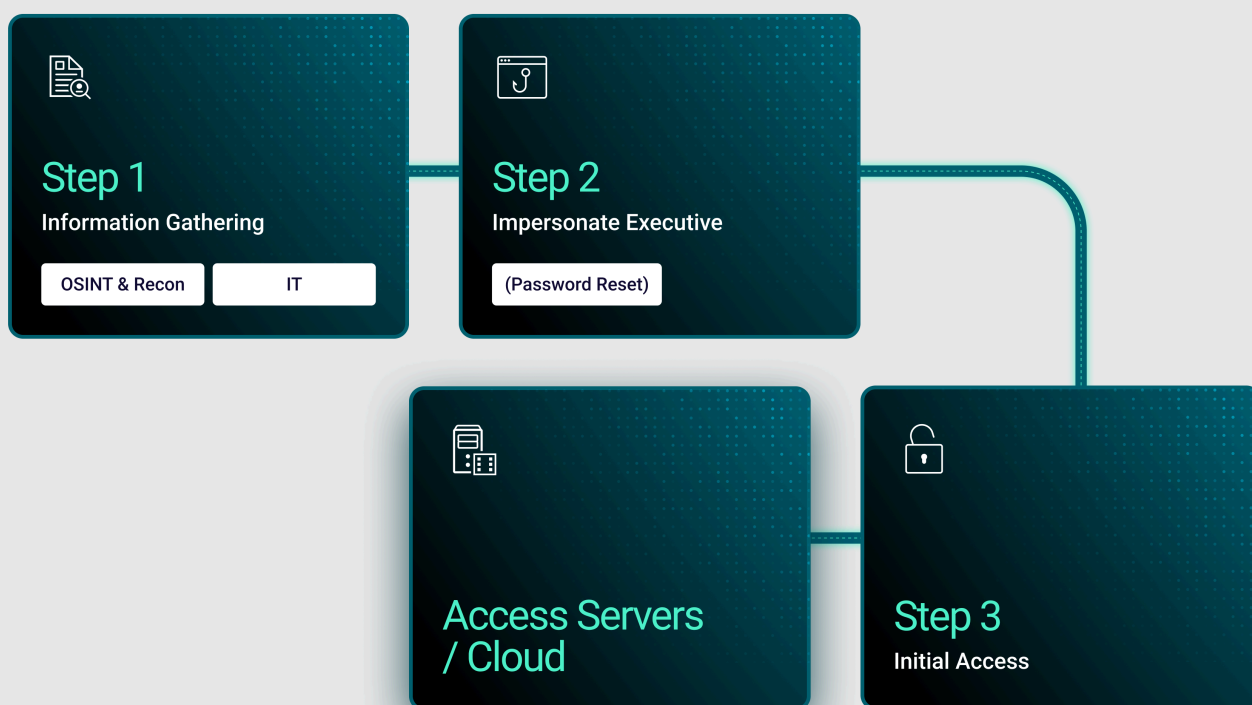
Scattered Spider Masters Human Exploitation

This identity-centric playbook has become the signature move of the Scattered Spider collective (aka “Octo-Tempest,” “UNC3944”). Active since 2022, this native-English-speaking group applied its tradecraft en masse in 2025, shifting from targeted strikes to widespread campaigns. The group’s focus stayed consistent across campaigns: Compromise platforms that provide centralized access, then pivot across the entire environment, hitting the finance, insurance, retail trade, and airline sectors in waves.

In multiple engagements, we saw attackers coerce IT administrators into resetting passwords or registering new MFA devices, effectively converting legitimate identities into attacker-controlled accounts. By impersonating executives, they exploited the inherent trust placed in internal requests to bypass verification protocols. In one investigated incident, Scattered Spider impersonated a CFO and used pre-collected personal information—such as date of birth and Social Security Number (SSN) fragments—to pass identity verification checks.

High-ranking employees often have extensive public-facing internet footprints, giving attackers the raw material to prepare, remove common roadblocks, and secure high-level privileges upfront. In one incident, once those permissions were in place, the pivot from initial entry to full system compromise took just 4 minutes.

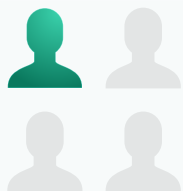
Scattered Spider Attack Chain



In our analysis of Scattered Spider voice phishing (vishing) calls, we found considerable expertise in psychological manipulation: confident corporate jargon, urgent tones to build rapport, and accents that occasionally “faded” or sometimes shifted to match the recipient. When help-desk agents pushed back, the attackers persisted, cycling calls until they reached someone who yielded. Their native English fluency made these interactions more credible and harder to dismiss than traditional vishing.

Social Engineering Featured in 26% of Incidents in 2025

In 2025, instead of bypassing security controls, attackers convinced people to disable them. Using employee impersonation and vishing, this technique, like ClickFix, reinforced one of the year’s defining patterns: attackers manipulating human decisions to gain access. In fact, 1 in 4 incidents we responded to in 2025 involved social engineering. By turning trusted organizational processes into tools for compromise, these attacks demonstrate that even the most expensive security stacks struggle against a valid account issued to the wrong person.



1 in 4

incidents involved social engineering for initial access

As long as human verification remains the fallback for account recovery and MFA resets, social engineering will persist. Preventative verification isn't foolproof, so the priority must shift to detecting the signals that follow a successful help-desk compromise—such as a password reset and immediate lateral movement—and responding in seconds, before valid access turns into a full-scale breach.



Take Action Against Social Engineering

- Strengthen verification for high-privilege accounts (like IT admins) or high-value accounts (like C-suite executives) by using out-of-band methods (e.g., callback on a registered number). Regularly test the help desk with social engineering drills to improve resistance to pressure tactics.
- Move high-value users and IT staff to FIDO2/WebAuthn hardware security keys, which provide phishing-resistant authentication and eliminate risks tied to mobile MFA methods like SMS or push notifications.
- Require managed service providers (MSPs), contractors, and privileged users to access critical systems through secure jumpboxes or privileged access management (PAM) solutions. Enforce MFA for all

internal RDP connections to and from jumpboxes to prevent lateral movement, even with compromised credentials.

Akira Exploits Public-Facing Devices: M&A Creates Hidden Risk

Exploitation of public-facing devices remains a reliable entry point. In 2025, we saw the “Akira” ransomware group [exploiting unpatched SonicWall VPN appliances inherited through mergers and acquisitions \(M&A\)](#) as a fast, low-friction entry point into larger enterprises. One overlooked remote-access device, still used by employees, contractors, or third parties, can become a direct path to domain compromise and ransomware deployment before the acquired environment is fully brought under standard controls.

Akira’s VPN Fast Track to Ransomware Deployment

From June through October 2025, we investigated a wave of Akira incidents relentlessly targeting this gap, where attackers gained access by exploiting unpatched vulnerabilities such as CVE-2024-40766 or brute-forcing weak credentials, and then pivoted into enterprise environments.

Akira, a financially motivated ransomware group active since 2023 and known for double extortion, consistently targets remote connectivity infrastructure because it is trusted; always on; and heavily used by employees, contractors, and third parties.

To stay under the radar during these incidents, Akira masked authentication attempts behind virtual private servers (VPS), blending into legitimate traffic and making detection significantly more difficult for defenders relying on geo-blocking or basic IP reputation filtering.

Across multiple incidents, once the group established access, attackers reach a domain controller in an average of just **9.3 hours—and in some cases in as little as 5**

hours. From there, lateral movement to ransomware deployment averaged just **1 hour.**



0 hours

Average time for attackers
to reach a domain controller



0 hour

Average time from lateral movement
to ransomware deployment

The M&A Risk Factor

Across the Akira-associated incidents we investigated, M&A was a consistent enabling factor. Akira repeatedly breached larger enterprises through inherited devices—assets that often sit in a governance gray zone during transition periods and carry forward legacy configurations, stale credentials, and delayed patching. These inherited edge devices become “unknown” or poorly monitored internet-facing entry points that attackers can use to bypass the acquiring company’s stronger, centralized controls.

How Akira Exploits M&A

Entry Point:

Inherited Devices Carry Forward Legacy Configurations



Brute-Force Stale Credentials



Exploit Unpatched Vulnerabilities

Obfuscation

VPS Masks Authentication



Evade Geo-Blocking and IP Reputation Filtering



Blend into Legitimate Traffic

Deployment

Domain Controller Provides Path to Lateral Movement



Establish Access



Navigate to Domain Controller



Deploy Ransomware

SonicWall appears in these scenarios largely because of its ubiquity in mid-market environments, driven by affordability and ease of use. We can't say with certainty whether Akira deliberately targeted SonicWall or the M&A process itself, but the pattern fits how ransomware groups operate. They gravitate towards targeting remote-access surfaces that are widely deployed, internet-exposed, and unevenly patched—conditions that worsen during rushed migrations and integration. This reality reflects the inherent risk of managing widespread remote-access fleets, not a flaw unique to any one vendor.

Incomplete asset inventories and patchy logging create blind spots that even robust security stacks cannot cover. Organizations should treat inherited infrastructure as part of the external attack surface from day one. Use automated discovery tools to immediately inventory internet-facing devices and identities brought in through M&A; force credential resets; patch aggressively; and bring logging and EDR visibility online (including VPN and authentication telemetry) before expanding connectivity.

Fundamentally, this is a problem of speed and coverage: If you can't quickly discover what assets you own and continuously confirm they're patched and monitored, attackers will.



Take Action Against Public-Facing Application Exploitation

- Review user accounts and permissions to identify orphaned accounts, stale credentials, excessive privileges, or shared credentials—especially on internet-facing devices like VPN appliances. Enforce least privilege by restricting Tier 0 (administrative) accounts to Tier 0 (critical) assets only to reduce credential theft and domain compromise paths.
- Capture and correlate native logs from all public-facing applications—including VPNs, firewalls, and remote-access gateways—for continuous visibility. Implement behavioral detection rules to identify unusual authentication patterns as attackers like Akira use VPS hosting to evade geo-blocking and blend in with legitimate traffic.
- Inventory, patch, and secure acquired systems immediately upon acquisition. Reset all credentials, apply critical updates, and integrate assets into standard security monitoring immediately. Restrict domain trusts and limit network connectivity between parent and subsidiary organizations until these security measures are in place, so cross-organizational traffic remains minimal until all assets are vetted and secured.

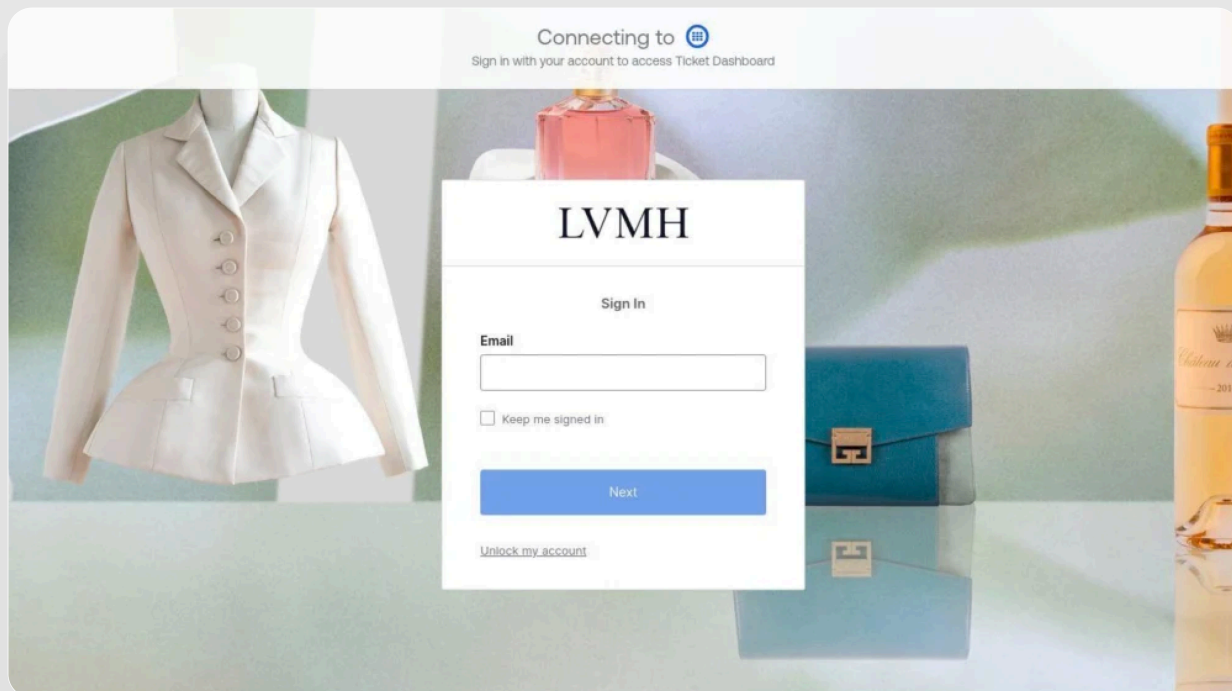
Typosquatting Still Works and It Scales into SaaS

Fake domains remain one of the most reliable paths to initial access because phishing basics still win. In 2025, we repeatedly saw threat actors weaponize typosquatted (deceptive lookalike) domains to steal credentials and OAuth tokens, using them to skip authentication checks and move directly into high-value software-as-a-service (SaaS) and cloud environments. By registering lookalike domains tailored to specific industries and services, attackers improved success rates and amplified the impact of each campaign.

This tactic isn't likely to fade. It's low-cost, consistently effective, and, when it succeeds, the access can look legitimate long enough for data theft to begin.

ShinyHunters Targets SaaS Platforms

One of the most impactful examples we tracked was a 4-month campaign by financially motivated threat group "ShinyHunters" targeting Salesforce customer relationship management (CRM) credentials. ShinyHunters gained notoriety in 2020 through a series of large-scale data breaches and extortion campaigns targeting global brands. In this campaign, we saw ticket-themed lures and domains that mimicked trusted support workflows and internal tools, exploiting predictable behavior like clicking "support" links without hesitation.



* Figure 2: A screenshot of a sign up form

[Our research revealed a pattern](#) that helps forecast likely targeting. Domains were registered in clusters, often shortly before public reporting on victim breaches, and frequently tailored to specific brands. They were carefully crafted to appear authentic, relying on slight spelling, structure, or branding variations. For example, we identified domains registered just days before a reported breach affecting a major fashion outlet:

- ticket-lvmh[.]com
- ticket-dior[.]com
- ticket-louisvuitton[.]com

Domains Blurred Across ShinyHunters, Scattered Spider, and Scattered Lapsus\$ Hunters

Through our investigation, we found evidence suggesting overlap or coordination between ShinyHunters and Scattered Spider, based on [domains impersonating technology vendors and access workflows](#). Many of the domains used terms

“helpdesk” and “SSO” to mimic sign-on portals, VPNs, and IT support systems, intentionally aiming for credentials that unlock infrastructure-level access.

Later in the year, we saw a resurgence in this technique when we identified [over 40 typosquatted domains impersonating Zendesk portals](#). In the process, we observed signs of a new coalition known as “Scattered Lapsus\$ Hunters” (which likely involves members of Scattered Spider, ShinyHunters, and hacking group “Lapsus\$”) operating the same playbook: Registering fake domains targeting SaaS platforms that unlocked downstream customer data and internal workflows, while early access still looked like normal sign-in activity. ShinyHunters’ launch of a data-leak site reinforced how quickly credential theft can turn into an end-to-end extortion pipeline.

The biggest advantage of this technique is its modularity. One group can build and scale the lure and domain ecosystem while another operationalizes the access for data theft or extortion. That blurs “who did what,” but more importantly, it accelerates campaigns and widens the blast radius, because proven infrastructure and playbooks can be shared, reused, or franchised across victims and sectors.

Fake domains aren’t new to defenders. They’re durable attacker infrastructure that provides early warning, victim forecasting, and low-friction access. Organizations need visibility into internet-facing identity and SaaS access paths—and the ability to rapidly validate and contain suspicious authentication tied to newly observed lookalike domains before phished access turns into data theft and extortion.



Take Action Against Fake Domains

- Require MFA with FIDO2 hardware security keys for all admin and support accounts. Pair with IP allowlisting and strict session timeouts to reduce the value of stolen credentials and tokens.
- Configure firewall, proxy, or DNS controls to block navigation to domains younger than 30 days.

- Restrict powerful permissions in SaaS applications to only trusted admins, audit privileges regularly, and centralize native identity/SaaS authentication logs to gain visibility into access paths. This rapidly validates and contains suspicious sign-ins tied to lookalike domains.

Your Strategy for Combatting Deception and Identity Threats

Organizations need adaptive defenses to prepare for and tackle modern initial access techniques, whether that means neutralizing ClickFix-style deception, countering Scattered Spider's help-desk social engineering, or staying ahead of evolving phishing tactics.

Automate and Streamline Phishing Responses

Phishing (with links or attachments) remained one of the top initial access risks in 2025. Proactive employee training and simulations reduce human error, but they don't close the gap on their own. Organizations also need tools like **GreyMatter Phishing Analyzer** that can automatically and holistically detect, investigate, and contain phishing attempts that bypass secure email gateways and land in user inboxes.

- ✔ **Cut the time-to-verdict on a reported phish:** Use AI to automate deconstruction, analysis, and enrichment of user-reported emails so security teams can determine malicious vs. benign in minutes, thereby reducing the window for initial access.
- ✔ **Limit impact after a click:** Coordinate response across email, network, and endpoint controls—including removing malicious messages, blocking payload delivery, and isolating affected devices—to prevent a single interaction from escalating into credential theft or follow-on compromise.

- ✓ **Contain the campaign, not just one email:** Scope at the campaign level to identify who received the message and who interacted with it so security teams can prioritize affected users, remediate at scale, and prevent repeat compromise.

Conduct Threat Hunting to Close Identity Hygiene Gaps

Attackers move too fast for purely reactive defense. The only way to stay protected is by implementing a proactive and predictive security operations program. Threat hunting helps surface and prioritize hygiene gaps that enable identity- and phishing-based intrusions—and drives remediation through enforcement controls and repeatable workflows. Examples of **threat hunting packages** available to GreyMatter customers include:

- ✓ **Cleartext Passwords in Document:** Identifies files containing plaintext credentials stored on user devices, often a symptom of missing password vault adoption. Using endpoint telemetry (for example syslog, Sysmon, or EDR), this package finds documents with cleartext passwords before attackers can enumerate and abuse them during post-compromise reconnaissance, allowing security teams to remediate risky files and enforce password vault adoption.
- ✓ **Spearphishing Attachments:** Flags spearphishing attempts using uncommon but business-relevant file extensions designed to evade filters. Using email gateway and endpoint telemetry, this package helps organizations rapidly identify higher-risk mail, correlate telemetry, and prioritize remediation (e.g., quarantine/purge, user follow-up, endpoint review).
- ✓ **MFA Modification:** Surfaces high-risk MFA events (new device registrations, resets) and highlights anomalous changes that can indicate account takeover. Use it to verify procedural compliance, spot suspicious identity changes early, and trigger response actions (e.g., session revocation, credential resets, access reviews).

Exposure-Led Compromise and an Alternate Reality of Initial Access

Unlike phishing and other user-driven initial access techniques, perimeter exploitation doesn't require persuasion—only something reachable and trusted left in an exploitable state. Whether it's a zero-day flaw, a refreshed variant of an established vulnerability, or a cloud misconfiguration, the outcome is the same: rapid initial access and expansion.

The crux of the problem lies in visibility and resilience. Defenders need to know what they own, what's exposed, and what they can't reliably see. They should then layer controls to achieve defense in depth against the known unknowns, but focus on detecting and containing what happens after entry, not just the specific exploit used.

The case studies that follow demonstrate just how quickly exposure can become active compromise. Each attack took a different path to compromise: a zero-day, a previously exploited vulnerability given new life, and leaked credentials. But they all share the same outcome—initial access that outpaces conventional response.

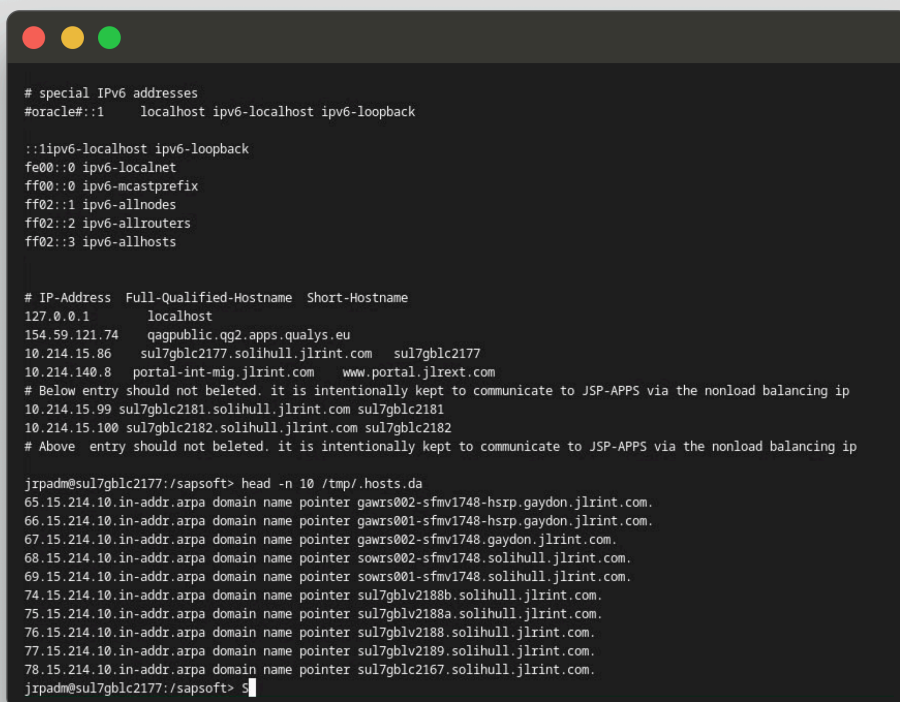
Attackers Exploit the Old and Forge the New in the 2025 Vulnerability Scene

Two of the year's big vulnerability stories showed both ends of the exploitation spectrum: A truly novel zero-day weaponized within days, and an "infamous" vulnerability resurfacing with updated tradecraft and faster timelines. The enterprise risk is the same; that is, once a high-impact exposure becomes usable at scale, multiple operators pile on quickly. That forces defenders to rely on defense in depth and fast containment rather than a single control, signature, or patch window.

ReliaQuest-Discovered SAP NetWeaver Zero-Day Sparked an Exploitation Snowball

In April 2025, [ReliaQuest identified a zero-day vulnerability in the technology integration platform SAP Netweaver](#) (CVE-2025-31324) with a CVSS score of 10.0. Initially suspected to be a remote file inclusion issue, we quickly confirmed it was an unrestricted file upload vulnerability. SAP subsequently released a patch. Within days, multiple threat actors adopted the same exploitation path, but post-exploitation tradecraft diverged rapidly, creating a snowball effect where one flaw produced many distinct intrusion patterns.

CVE-2025-31324 shows how [attackers adapt by turning a single exploit into many variants](#) that evolve over time. High-impact enterprise vulnerabilities deliver immediate ROI for attackers, and rapid reuse, combined with shifting tool sets, complicates attribution and overwhelms defenses by inspiring a chain reaction of exploitation. This preference also showed up in our analysis of vulnerability-related chatter on cybercriminal forums: Discussion and exploit sales focused on widely deployed enterprise security and infrastructure platforms, where one exploit can turn into thousands of potential victims.



```
# special IPv6 addresses
#oracle#::1 localhost ipv6-localhost ipv6-loopback

::1ipv6-localhost ipv6-loopback
fe80::0 ipv6-localnet
ff00::0 ipv6-mcastprefix
ff02::1 ipv6-allnodes
ff02::2 ipv6-allrouters
ff02::3 ipv6-allhosts

# IP-Address Full-Qualified-Hostname Short-Hostname
127.0.0.1 localhost
154.59.121.74 qagpublic.qg2.apps.qualys.eu
10.214.15.86 sul7gblc2177.solihull.jlrint.com sul7gblc2177
10.214.140.8 portal-int-mig.jlrint.com www.portal.jlrext.com
# Below entry should not be deleted, it is intentionally kept to communicate to JSP-APPS via the nonload balancing ip
10.214.15.99 sul7gblc2181.solihull.jlrint.com sul7gblc2181
10.214.15.100 sul7gblc2182.solihull.jlrint.com sul7gblc2182
# Above entry should not be deleted, it is intentionally kept to communicate to JSP-APPS via the nonload balancing ip

jrpadm@sul7gblc2177:/sapsoft> head -n 10 /tmp/.hosts.da
65.15.214.10.in-addr.arpa domain name pointer gawrs002-sfmv1748-hsrp.gaydon.jlrint.com.
66.15.214.10.in-addr.arpa domain name pointer gawrs001-sfmv1748-hsrp.gaydon.jlrint.com.
67.15.214.10.in-addr.arpa domain name pointer gawrs002-sfmv1748.gaydon.jlrint.com.
68.15.214.10.in-addr.arpa domain name pointer sows002-sfmv1748.solihull.jlrint.com.
69.15.214.10.in-addr.arpa domain name pointer sows001-sfmv1748.solihull.jlrint.com.
74.15.214.10.in-addr.arpa domain name pointer sul7gblv2188b.solihull.jlrint.com.
75.15.214.10.in-addr.arpa domain name pointer sul7gblv2188a.solihull.jlrint.com.
76.15.214.10.in-addr.arpa domain name pointer sul7gblv2188.solihull.jlrint.com.
77.15.214.10.in-addr.arpa domain name pointer sul7gblv2189.solihull.jlrint.com.
78.15.214.10.in-addr.arpa domain name pointer sul7gblc2167.solihull.jlrint.com.
jrpadm@sul7gblc2177:/sapsoft> $
```

* *Figure 3: SAP Scattered Lapsus\$ Hunters POC post*

Across attacks tied to this zero-day, the initial access method stayed consistent. Adversaries used the unrestricted file upload flaw to gain code execution and implant web shells, establishing a foothold deep in the environment. After entry, attacks got more complex. In some cases, attackers used the Heaven's Gate anti-detection technique to execute 64-bit payloads from a 32-bit context, reducing the effectiveness of EDR coverage focused narrowly on the 32-bit subsystem.

Once inside, operating under the radar, the tools used varied between actors. We saw payloads consistent with Brute Ratel (a commercial red-team command-and-control [C2] framework often abused by threat actors) and "PipeMagic," which established backdoors via Windows-named pipes, leveraging a built-in communication channel that evades network-based detection. The gap between a relatively simple entry method and highly advanced post-exploitation tools suggests a decoupled kill chain. This aligns with initial access broker (IAB) behavior: Secure entry and then sell access to other operators who bring their own tool kits.

This potential rotation of actors and snowball effect created a muddled landscape for defenders. Even with a consistent exploit vector, the post-exploitation footprint shifted with every new operator. Defenders couldn't simply hunt for a single C2 signature or tool set to scope the breach, because the post-exploitation "smoke" changed depending on who had bought the fire.

When a vulnerability is new and exploitation is active, resilience can't depend on a single control. Layer your defenses—rapid exposure identification and mitigation, strong identity controls, network segmentation, and behavior-based detection—to establish defense in depth. This approach holds even when any single layer fails. What matters then is detecting what attackers do after entry (establish persistence, escalate privileges, and move laterally), not which tool they choose.

Citrix Bleed 2 Showed Old Vulnerabilities Still Have Teeth

2025 also showed us that old vulnerabilities matter just as much as new flaws. Instead of fading, they become playbooks. Attackers reuse what works, adjust the tradecraft, and apply it at scale.

We saw this play out in the days leading up to the public disclosure of Citrix Bleed 2 (CVE-2025-5777). We noticed [suspicious activity on a customer's Citrix NetScaler appliance](#). We observed unexpected session terminations, abnormal session reuse across multiple IP addresses, and traffic patterns originating from data-center hosting providers.

Further investigation confirmed that attackers had already weaponized the flaw. By extracting session tokens from memory, they bypassed authentication and appeared inside the network as legitimate users, then quickly pivoted into Active Directory (AD) reconnaissance and lateral movement—all before a patch was widely available.

This is why "infamous" vulnerabilities matter long after their disclosure. [The original Citrix Bleed \(2023\)](#) was more than just a one-time incident wave. It taught attackers where to look, what success looks like operationally, and how defenders tend to respond. When similar conditions emerged again, threat actors moved quickly, even without a public proof of concept (PoC).

Patching remains essential, but it doesn't eliminate risk on its own. And it doesn't always arrive before exploitation begins. Attackers iterate on familiar exploit themes

and move quickly against exposed systems, creating a recurring cycle of old techniques and new CVEs. And with advancements in AI, these cycles are likely to accelerate, making it faster for attackers to identify and exploit recurring weaknesses in complex attack surfaces.

Defenders need sustained visibility into exploitation behavior and the ability to respond before session hijacking or lateral movement turns an exposed service into a breach.



Take Action Against Vulnerability Exploitation

- Monitor web server logs for exploit primitives (e.g., unusually large HTTP headers associated with Citrix Bleed 2 attacks) and watch for session anomalies like “impossible travel” violations or concurrent token use across multiple IP addresses to catch hijacking attempts even when the exploit is unknown.
- Restrict access to administrative portals using network access control lists (ACLs), limiting access to internal management subnets wherever possible. As a result, the attack surface for external opportunistic exploitation is drastically reduced.
- Patch by risk (prioritize internet-facing SAP and VPN infrastructure); use virtual patching (web application firewalls [WAF] and intrusion prevention systems [IPS]) when fixes aren’t yet available; and assume exploitation will occur. Prepare by mapping high-risk assets and attack paths, maintaining offline backups, and hunting for post-exploitation behaviors (e.g., C2).

Small Missteps and Big Consequences in Cloud Misconfigurations

New CVEs and high-profile vulnerabilities can be weaponized at speed, but the cloud incidents we investigated in 2025 followed a simpler pattern. Attackers didn't need a breakthrough vulnerability when misconfigurations and over-privileged identities provided an easier path.

Cloud Risk Is Driven by IAM Abuse and Compute Misconfiguration

Across incidents in customer cloud environments last year, the highest-impact activity mapped back to 2 preventable failures:

Identity and Access Management: Identity and Access Management (IAM) issues emerged as the primary source of cloud risk, accounting for **44%** of alerts; within those, **52%** involved privilege escalation. **Nearly half** of verified cloud incidents involved abuse of valid credentials, often tied to over-privileged cloud identities. Wildcard permissions (*) and excessive administrative roles remain prime targets for attackers as they make escalation and high-impact access straightforward.

Process breakdowns: Compute resources (virtual machines [VMs], serverless functions, and containers) were involved in **43%** of incidents, often through misconfigurations like exposed storage buckets, unpatched vulnerabilities, and overly permissive network rules. Mismanaged permissions in Continuous Integration and Continuous Delivery (CI/CD) pipelines were particularly dangerous, enabling lateral movement across environments. By compromising a single pipeline configuration, attackers could hijack the automated deployment process, turning legitimate software delivery tools into a mechanism for pushing malicious code or infrastructure changes directly into production.



Percentage of alerts that originate from IAM issues.

0%

Percentage of cloud alerts involving privilege escalation.

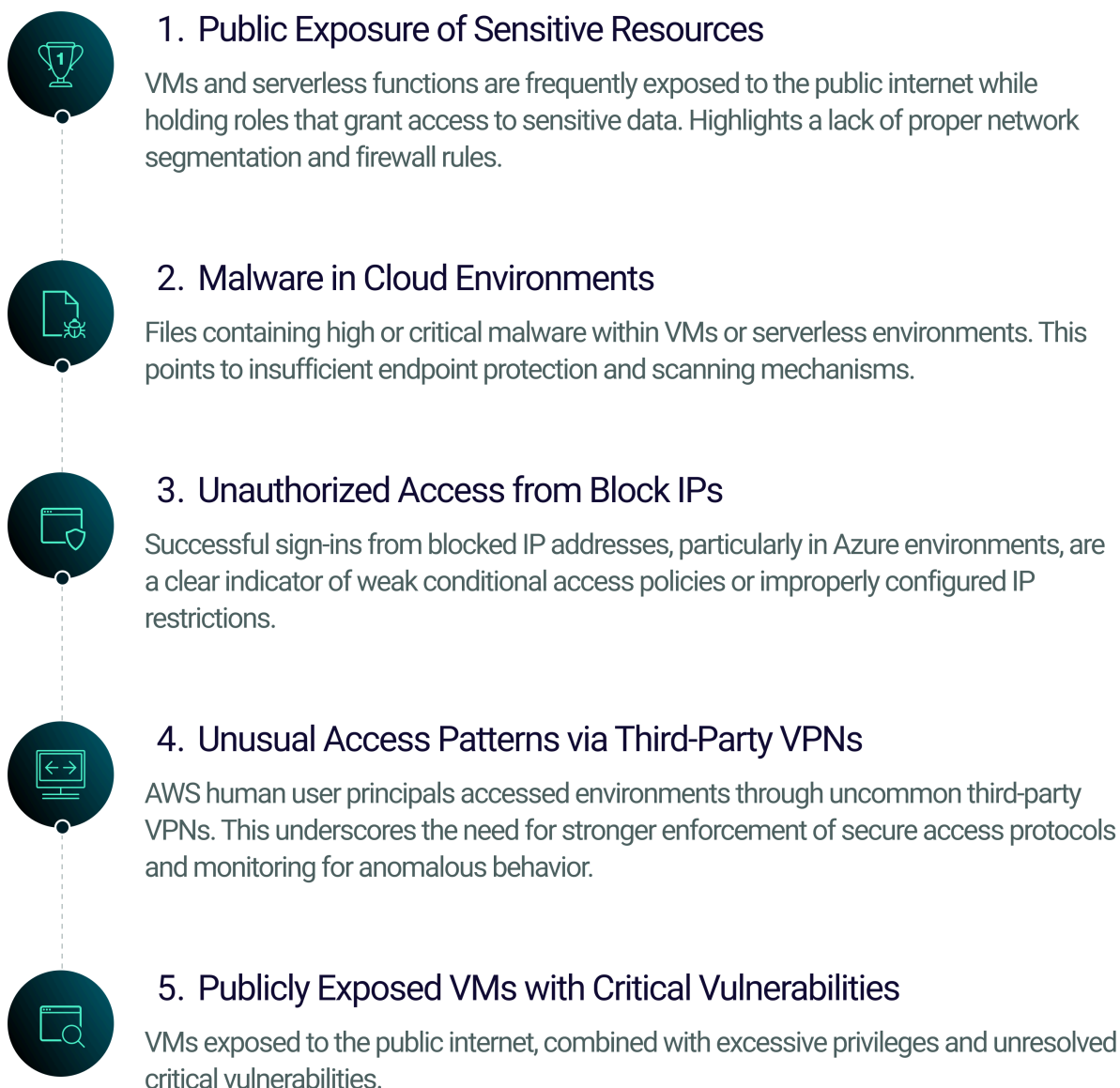
0%

Percentage of incidents involving compute resources

Key Misconfigurations Driving Cloud Risk

Attackers thrive on gaps in visibility, access control, and resource protection. Our investigations revealed that the most common missteps driving high-risk incidents included public exposure of sensitive resources and excessive privileges on vulnerable VMs.

Cloud interdependence compounds the effect of any misconfiguration. A misconfigured VM can become a gateway into CI/CD pipelines, collaboration tools, and automation frameworks. Attackers use that interconnectedness to turn a small foothold into broad compromise.



** Figure 4: Top cloud risks and misconfigurations*

Exploiting the Cloud One Credential at a Time

Many cloud security issues boil down to a single leaked credential. With valid credentials in hand, attackers can use automated tools to rapidly scan, validate, and exploit secrets, then pivot across interconnected cloud services. Organizations often struggle to detect credential misuse in real time due to visibility gaps in IAM logs and API usage patterns. These are blind spots that attackers can use to operate undetected for extended periods.

In one incident we analyzed, attackers used the legitimate open-source tool TruffleHog to scan public repositories and Slack channels for forgotten AWS keys. After validating them, they used the `GetCallerIdentity` command to map permissions and identify over-privileged accounts.

From there, they located and drained sensitive data from S3 buckets while simultaneously scanning internal Slack workspaces for additional tokens. By abusing trust relationships in CI/CD pipelines, they moved laterally across services, effectively turning the organization's own automation infrastructure into the attack path.

A strong perimeter doesn't matter if valid credentials are scattered inside the environment. One key left in a chat log is enough to bypass defenses, escalate privileges, and take full control of a cloud environment. Cloud misconfigurations can drive data breaches, regulatory fines, reputational damage, and operational disruption.



Take Action Against Cloud Risks

- Secure collaboration tools by restricting sensitive data sharing in platforms like Slack or Teams. Enable automated scans to catch exposed secrets in chat logs and file uploads before they become entry points.
- Replace risky long-term keys with short-term, temporary credentials using services like AWS Security Token Service (STS). These expire quickly, drastically shrinking the window of opportunity for attackers if a key is leaked.
- Enforce least privilege by using IAM analysis tools to automatically identify and strip unused permissions. Regular credential rotation

(especially for CI/CD pipelines) further limits the blast radius of any potential compromise.

Your Strategy for Combatting Vulnerabilities and Cloud Threats

Organizations can stay ahead of a volatile vulnerability landscape and complex cloud risk by combining comprehensive visibility, actionable intelligence, and AI-driven automation. This ensures exposures are identified, prioritized, and remediated before attackers can exploit them.